Legislation and Policies Report

Created by

Jaineel

For

Angelonia Fashion and Turtle Movers

PROJECT REFERENCE:

DATE:25/10/25

Contents

1 Abstract 3

2 Introduction 4

3 Cyber Security Legislative and Regulatory Review 4

3.1 Regulators 5

4 Cyber Security Findings and Recommendations 5

5 Privacy Policies and Best Practices Review 6

6 Privacy Compliance Findings and Recommendations 6

7 Ethical behaviour in cyber security 7

7.1 Code of Practice (for only one of the two organisations) 7

7.2 Ethical practices (this part covers both organisations) 7

8 Conclusion 8

Appendix 9

Organisation policies, procedures and best practices documentation 9

1 Abstract

This report provides an analysis of the cybersecurity posture, legal compliance, and data protection obligations for Angelonia Fashion and Turtle Movers. Both organisations operate online and manage personal and financial data, meaning they are subject to Australian laws, including the *Privacy Act 1988 (Cth)*, and are indirectly impacted by international frameworks such as GDPR and PCI-DSS due to their use of online services, cloud providers, and payment gateways.

The investigation determined that while both companies have foundational policies for privacy, security practices, and customer data handling, there are notable deficiencies. These include a lack of standardisation, inconsistent reporting procedures, and insufficient formal documentation for cyber risk management, access control, staff awareness training, and incident response. Furthermore, international compliance obligations (especially GDPR and PCI-DSS) necessitate stronger data protection, greater use of encryption, limited data retention, and improved transparency for online customers.

Key risks identified are potential data breaches from unauthorised access, inadequate employee cyber awareness, reliance on third-party cloud services, and the possibility of regulatory penalties due to non-compliance. The unauthorised or illegal misuse of cybersecurity skills or system access was highlighted as carrying severe legal, civil, and reputational consequences.

The report recommends that both companies enhance their cyber maturity. This should be achieved through the implementation of clearer and more formalised policies, scheduled cyber awareness training, improved monitoring and incident reporting, closer alignment with international data security standards, and regular auditing of third-party service providers. Adopting these measures will enhance compliance, safeguard customer data, reduce overall risk exposure, and bolster trust and credibility with clients and stakeholders.

2 Introduction

This report was prepared for MidTown IT, where I work as a Cyber Security Analyst and Consultant. Its primary aim is to evaluate how two of Midtown's client organisations, Angelina Fashion and Turtle Movers, handle their cybersecurity, privacy, and ethical responsibilities.

Initially, both companies and their clients began as small enterprises but have rapidly grown into medium-sized firms. This swift expansion now introduces new risks, especially regarding data security and cyberlaw compliance. Angelina Fashion, active in fashion and retail with online, brick-and-mortar, and international exports, contrasts with Turtle Movers, a logistics company providing nationwide removalist services across Australia.

This report will look at four key areas:

- The laws, regulations and standards that govern each organisation
- How effectively their current privacy policies and procedures align with the Australian Privacy Principles
- The ethical behaviour expected of cybersecurity staff and its relevance to both organisations
- A final set of recommendations to assist both companies in enhancing their compliance, privacy management, and staff awareness.

3 Cyber Security Legislative and Regulatory Review

Angelonia Fashion operates within the fashion retail and e-commerce sectors. It offers clothing and accessories through physical stores, online platforms, and some international exports under its own brand. Since the business manages customer payment data, personal details, and engages in international transactions, it must adhere to strict Australian privacy, consumer, and cybersecurity laws, as well as relevant international data protection regulations. The company’s key data activities encompass online sales, refunds, credit card processing, and supplier dealings.

Turtle Movers operates within the transport and logistics sector, providing online-only removalist services throughout Australia. The company handles bookings, payments, insurance claims, and customer interactions exclusively via its website. Because its operations are fully digital, Turtle Movers relies heavily on secure online platforms and data storage. It must comply with national privacy and cybersecurity regulations, including the Privacy Act 1988 (Cth), the Criminal Code Act 1995 (Cth), and the Spam Act 2003 (Cth), to protect client information and ensure data security.

While Angelonia Fashion must adhere to additional international regulations like GDPR because of its overseas sales, Turtle Movers mainly complies with Australian Federal and

State privacy laws. Both organisations face similar challenges, including handling sensitive customer data, relying on third-party payment processors, and requiring robust internal controls to protect and process this information.

SECTOR:				
CYBER SECURITY and Related LEGISLATION	**SCOPE**			**BUSINESS AREAS/ACTIVITIES AFFECTED**
	Federal	State	Territory	
Privacy Act 1988 (Cth)	**Yes**	No	No	Collection, storage and use of customer and employee data, personal information, online sales data and marketing records
Notifiable Data Breaches Scheme	**Yes**	No	No	Data Breach response, incident reporting, and customer notifications
Spam Act 2003	**Yes**	No	No	Marketing emails, customer communications and newsletters
Criminal Code Act 1995 - Cybercrime	**Yes**	No	No	Prevent hacking, unauthorised access and malware
Work Health & Safety Act 2011	**Yes**	**Yes**	**Yes**	Cyber awareness training, proper and safe IT use and practice for staff for proper security
	☐	☐	☐	
	☐	☐	☐	Add rows as required

Company 1 – Angelonia Fashion

1. Business operations (overview)

Angelonia Fashion is an Australian fashion retailer that sells garments to customers through online transactions. Its operations involve:

- Collecting customer contact details (name, address, email, phone)
- Processing online orders, payments, refunds and returns
- Storing limited banking/credit details via payment methods
- Using cookies on its website to personalise the online experience
- Running email/SMS marketing to subscribed customers
- Using internal systems for administration, tax records and marketing.

Most of Angelonia's activities appear to be focused on Australian customers. Still, its website and online store are internet-facing, which means it could receive visits or orders from overseas customers.

2. International cybersecurity/privacy legislation that may impact Angelonia

Angelonia's primary legal obligation is Australian law (Privacy Act 1988 (Cth)), but some international frameworks can still affect how it must secure data, especially if:

- Overseas customers place orders, or
- The website targets customers outside Australia, or
- It uses cloud or payment providers that are subject to overseas laws.

Relevant international influences include:

- EU / UK GDPR (General Data Protection Regulation)
    - May apply if Angelonia:
        - accepts orders from EU/UK customers, or

        - targets EU/UK users (e.g. shipping options, prices, or marketing directed at those regions).

    - GDPR requires strong protection of personal data, clear consent, limited retention, and breach notification for affected individuals.

- International payment security standards (e.g. PCI-DSS)

    - Not a “law”, but an international standard used by banks/payment gateways.

    - Because Angelonia takes online payments, its payment processor must comply with PCI-DSS and enforce strong technical controls (encryption, secure transmission, etc.), which indirectly affects Angelonia’s data security.

- Cloud / third-party providers’ compliance obligations

    - If Angelonia uses overseas-hosted platforms (e.g. SaaS shopping carts, email marketing tools), those services may be required to comply with GDPR or other overseas regulations.

    - Angelonia needs to align its practices with the security and privacy terms imposed by those providers.

3. Areas of Angelonia’s business affected by international legislation/standards

International frameworks mainly affect:

- Website and cookies

    - Use of cookies for tracking, personalisation and analytics.

    - For EU/UK users, GDPR-style rules would require clearer consent for non-essential cookies.

- Online ordering and payments

    - Handling of customer details and payment information via international payment gateways and e-commerce platforms.

    - PCI-DSS influences how card data is processed and secured.

- Customer accounts and marketing

    - Storage of email addresses and phone numbers for marketing.
    - Consent, unsubscribe mechanisms and secure handling of subscriber lists.
- Cloud storage and backups
    - If any customer data is stored or backed up on servers outside Australia, those environments and providers must follow appropriate security and privacy obligations.

4. Impact on Angelonia's business operations and data security

- Higher security expectations
    - International rules like GDPR and PCI-DSS push Angelonia to use stronger technical controls (encryption, access control, secure websites, strong passwords).
- Changes to how data is collected and retained
    - Angelonia must limit personal data to what is necessary for the transaction and only keep it for as long as required (e.g. for tax or warranty).
- More formal privacy and security processes
    - Clearer privacy notices, consent for marketing, cookie information, and defined breach response procedures.
- Compliance overhead vs. benefits
    - There is extra work to keep policies, procedures and systems aligned with international standards.
    - In return, Angelonia improves its overall data security, reduces the risk of breaches, and builds trust with customers, including any overseas buyers.

Overall, while Angelonia is an Australian retailer, international cybersecurity and privacy frameworks (especially GDPR and PCI-DSS through its payment and cloud providers) influence how it must protect personal and payment data in its online operations.

Company 2 – Turtle Movers

1. Business operations (overview)

Turtle Movers is an Australian removalist company that provides moving and transport services. Its operations involve:

- Collecting customer contact details (name, pickup address, delivery address, email, phone)
- Managing bookings, cancellations, rescheduling and insurance details
- Processing payments, refunds, and loyalty/rewards information
- Storing payment/banking details via payment methods
- Keeping correspondence records (emails, phone calls, messages)
- Using online forms and transactions for service bookings.

Like Angelonia, Turtle Movers appears to focus on Australian customers, but because services and queries are handled online, it may occasionally interact with overseas customers planning moves or making enquiries.

2. International cybersecurity/privacy legislation that may impact Turtle Movers

The main legal framework for Turtle Movers is Australian privacy law, but international legislation and standards can still affect its data security in similar ways:

- EU / UK GDPR
    - Could apply if Turtle Movers collects personal data of EU/UK residents (for example, customers arranging moves from or to Australia, or making bookings while still overseas).
    - GDPR emphasises secure processing, data minimisation, limited retention, and the right of individuals to access or request deletion of their data.
- International standards used by service providers
    - If Turtle Movers uses third-party cloud services, CRM systems or booking platforms hosted overseas, those services might be required to comply with GDPR or other international security standards (ISO 27001, SOC 2, etc.).

    - Turtle Movers must ensure its own practices align with the security and privacy controls defined in those provider agreements.

- Payment processing standards (PCI-DSS)
    - Again, not “law” but an international standard enforced by financial institutions and payment gateways.
    - Because Turtle Movers takes electronic payments, its payment processors require strong security for cardholder data, which affects how payment data is transmitted and stored.

3. Areas of Turtle Movers’ business affected by international legislation/standards

- Online booking and payment systems
    - Forms and systems are used to capture booking details, addresses, and payment information.
    - Need for encryption (HTTPS), secure authentication, and careful control of access to customer records.
- Customer data storage and retention
    - Retention of booking and transaction records for tax purposes.
    - Proper destruction of data once retention periods are over, especially where data is stored on overseas or cloud systems.
- Complaint handling and communication
    - The structured privacy complaint process means customer data is processed during investigations; international expectations emphasise secure handling and limited sharing.
- Cloud backups and third-party services
    - Any use of hosted email, file storage, or CRM services that may store data outside Australia must meet appropriate security and privacy requirements.

4. Impact on Turtle Movers’ business operations and data security

- Improved technical and organisational controls
    - International standards drive Turtle Movers to maintain strong passwords, encryption, backups, endpoint protection, and proper disposal of customer data – as already reflected in its privacy practices.
- More robust handling of complaints and incidents
    - The detailed complaint procedure supports better transparency and accountability, consistent with international expectations around privacy and data protection.
- Vendor and cloud risk management
    - Turtle Movers must be careful when choosing booking systems, email providers and storage platforms, ensuring they apply strong security and, where relevant, meet GDPR-aligned or similar requirements.
- Overall effect
    - While there may be no direct legal obligation under foreign laws for a purely domestic mover, international cybersecurity and privacy frameworks still shape the standards expected of Turtle Movers and its providers.
    - This leads to better protection of customers' personal information, reduced risk of breaches, and higher customer confidence.

INTERNATIONAL CYBER SECURITY LEGISLATION	BUSINESS AREAS/ACTIVITIES AFFECTED	IMPACT on DATA SECURITY
EU / UK GDPR (General Data Protection Regulation) – Angelonia	• Website interactions by visitors from the EU/UK. • Online sales transactions. • Use and management of cookies. • Administration of customer accounts. • Marketing communications via email and SMS.	This legislation mandates enhanced consent management and stricter limits on data retention. It also strengthens requirements for encryption, access control, and robust breach notification procedures.
PCI-DSS (Payment Card Industry Data Security Standard) – Angelonia	Online payments and order processing	Requires secure transmission and storage of card data through encryption, access control, and secure systems to prevent credit card fraud and data breaches.
EU / UK GDPR – Turtle Movers	Online booking forms, customer enquiries from overseas, and CRM usage	Requires secure and transparent handling of customer data, including limitations on unnecessary collection and secure storage and eventual deletion following defined retention periods.
International Cloud/Hosting Standards (e.g., ISO 27001, GDPR obligations of third-party services) – Turtle Movers	Email platforms, cloud storage, and booking software hosted offshore	Mandates that vendors and cloud services adhere to established security standards. This directly influences access controls, encryption practices, and incident response protocols, ultimately mitigating the risk of unauthorised access or data leakage.

Interdependencies, Regulators, and Reform Impacts

1. Interdependency Between Cybersecurity Legislative Instruments

Australia's cybersecurity landscape is governed by an interconnected web of legislation, rather than isolated laws, forming a comprehensive regulatory structure. A significant example of this interdependency is the relationship between the Privacy Act 1988 (Cth) and the Security of Critical Infrastructure Act (SOCI Act).

- Organisations are obligated under the Privacy Act to safeguard personal information. This includes ensuring secure data handling practices and adhering to the Notifiable Data Breach (NDB) scheme, which requires informing individuals of serious data breaches.

- The Security of Critical Infrastructure (SOCI) Act mandates that sectors deemed critical (such as energy, telecommunications, and data storage) must implement compulsory cybersecurity risk management programs. Furthermore, these entities are required to report any cyber incidents to the Australian Cyber Security Centre (ACSC).

Interdependency:
Both the Security of Critical Infrastructure Act 2018 (SOCI Act) and the Privacy Act 1988 necessitate strong cybersecurity controls for organisations. Critically, cybersecurity measures implemented to comply with the SOCI Act simultaneously assist in meeting the obligations of the Privacy Act, particularly Australian Privacy Principle (APP) 11 regarding the security of personal information. Therefore, a deficiency in an organisation's cybersecurity posture compromises compliance with both privacy and critical infrastructure legal requirements. Essentially, maintaining robust cybersecurity is fundamental to complying with both sets of legal obligations.

2. Impact of Key Regulators on Business Data Security

Several Australian regulators influence how organisations manage data security:

a) Office of the Australian Information Commissioner (OAIC)

The Privacy Act and the Notifiable Data Breach scheme are enforced by this entity.

Its responsibilities include:

- Investigating data breaches and privacy complaints.
- Issuing penalties when necessary.

Businesses are impacted as they must adhere to requirements for:

- Secure data storage.
- Strong access control measures.
- Timely notification of data breaches.
- Transparent privacy policies.

b) Australian Communications and Media Authority (ACMA)

- Regulates spam, telemarketing, and digital marketing.

- Impacts organisations by enforcing rules around consent, direct marketing, and communication security.

c) Australian Competition and Consumer Commission (ACCC)

- Regulates misleading conduct, unfair business practices, and consumer rights.

- Impacts organisations by requiring:
    - transparent handling of consumer data
    - truthful statements about security practices
    - adherence to consumer protections relating to digital systems

Impact Summary:

These regulators ensure that organisations:

- collect and use data ethically
- Maintain strong cybersecurity controls
- avoid deceptive data handling practices
- protect customers from privacy misuse

Failure to comply can lead to investigations, fines, reputational damage, and mandatory corrective actions.

3. **Current and Upcoming Reforms in Privacy Legislation (Impact on the Organisation)**

Key Reforms to Australia's Privacy Act 1988 (Based on Attorney-General's Review)

Australia is currently reforming the Privacy Act 1988, introducing key changes to data handling and consent:

1. **Strengthened Consent Requirements**
    - **Reform:** Organisations are now required to obtain **clear, informed, and unambiguous** consent from individuals.
    - **Impact:** MidTown IT's clients, such as Angelonia and Turtle Movers, must immediately update their consent protocols for data collection and marketing

activities.

2. **Introduction of the "Fair and Reasonable" Test**
    - **Reform:** Data practices must be proven to be fair, necessary, and not excessive in scope.
    - **Impact:** Both Angelonia and Turtle Movers must justify *every* type of personal data they collect and eliminate any unnecessary or excessive data fields.
3. **Increased Penalties for Serious Privacy Breaches**
    - **Reform:** Penalties for serious breaches will significantly increase, potentially rising to millions of dollars.
    - **Impact:** To mitigate financial risk, both organisations must enhance their security controls, refine incident response plans, and boost staff training on privacy and security.

d) Enhanced Individual Data Rights (Similar to GDPR)

Key rights include:

- Right to erasure
- Right to explanation
- Stronger data access rights

Impact: Both Angelonia and Turtle Movers must establish formal processes to manage requests for data access, correction, and deletion.

e) Stricter Requirements for Data Minimisation and Retention

Organisations are prohibited from storing personal data for longer than is strictly necessary.

Impact: Angelonia needs to broaden its data retention schedules beyond current taxation requirements, and Turtle Movers must formalise its data disposal processes.

4. Impact of Consumer and Surveillance Legislation Reforms on the Organisation

Consumer Law Reforms (ACCC)

Recent legislative reforms led by the ACCC concentrate on bolstering consumer protection in the digital domain. Key areas of focus include:

- Safeguarding consumers from unfair digital business practices.
- Mandating greater transparency in organisational data collection processes.
- Prohibiting the use of 'dark patterns,' such as forced opt-ins, to secure user consent.
- Establishing a regulatory framework for digital platforms.

Organisational Impact:

These reforms necessitate that businesses adapt their practices, specifically by:

- Articulating data usage policies in clear, straightforward language.
- Eliminating misleading or deceptive consent mechanisms.
- Upholding ethical standards for all marketing data practices.

- Enhancing overall transparency in online interactions with customers.

Consequently, both Angelonia and Turtle Movers are required to update their website terms, marketing opt-in procedures, and consent documentation to align with these new legal requirements.

Surveillance Legislation Reforms and Organisational Impact

The recent reforms to surveillance legislation focus on several key areas:

- **Employee Monitoring:** Regulations governing the surveillance of staff.
- **Data Collection Technology:** Rules related to the use of CCTV monitoring and the collection of biometric data.
- **Digital Transparency:** Requirements for clear disclosure regarding digital tracking methods.
- **Mandatory Notification:** New requirements for providing formal notice about surveillance practices.

Impact on Organisations

These reforms necessitate specific actions from businesses:

- **Physical Monitoring:** Organisations using CCTV or other monitoring tools (e.g., in retail stores or warehouses) must update their policies and ensure clear signage is in place.
- **Staff Surveillance:** Any monitoring of employees must be legally compliant, fully disclosed to staff, and have a clear, justifiable purpose.
- **Digital Tracking:** The use of tracking technologies, such as website cookies or session monitoring, must be transparent to the user.

Specific Organisational Examples:

- **Angelonia:** As Angelonia utilises cookies, they are required to expand their current policy to:
    - Detail the specific data collected by cookies.
    - Provide users with tools for opting out of and managing cookie settings.
    - Confirm that all cookie practices adhere to the latest privacy and consumer law reforms.
- **Turtle Movers:** As a logistics company, Turtle Movers likely uses tracking tools (e.g., GPS for vehicles, delivery monitoring). The use of these tools must be formally documented and clearly communicated to both employees and customers.

3.1 Regulators

Introductory paragraph.

For each of the regulators presented below, identify and explain their role and scope.

REGULATOR	ROLE	SCOPE
Australian Prudential Regulation Authority (APRA)	The Australian Prudential Regulation Authority (APRA) is responsible for the financial stability and risk management of various entities, including banks, insurance companies, and superannuation funds. To ensure these regulated entities safeguard sensitive financial and customer data, APRA develops and enforces specific cybersecurity standards.	This requirement is primarily applicable to the banking, insurance, and superannuation industries. It becomes relevant when organisations engage financial service providers that are mandated to adhere to APRA's CPS 234 information security standards.
Australian Securities and Investments Commission (ASIC)	The Australian Securities and Investments Commission (ASIC) is responsible for regulating financial markets and corporations, as well as enforcing laws designed to safeguard investors, consumers, and creditors. ASIC monitors the cyber resilience of companies and has the authority to intervene if inadequate cybersecurity results in failures of governance duties or misleading conduct.	This legislation is applicable to Australian-registered companies, financial service licensees, and entities involved in financial markets. It is pertinent whenever a business manages payments, provides credit, or depends on secure financial infrastructure.
Australian Competition and Consumer Commission (ACCC)	The ACCC plays a key role in enforcing consumer protection laws, overseeing fair trading practices, and	This legislation is applicable to all Australian businesses, including those operating online, such as retailers and

	preventing conduct that is misleading or deceptive. This includes holding businesses accountable for transparency in the collection, use, and security of customer data, particularly on online platforms.	service providers. It encompasses a range of topics, including online transactions, marketing practices, the use of cookies, data handling representations, and privacy claims.
Australian Energy Sector Cyber Security Framework (AESCSF)	AESCSF provides cybersecurity standards and maturity guidelines specifically for the Australian energy sector to improve resilience against cyber threats affecting critical infrastructure.	This framework is specifically for organisations in the energy sector (electricity, gas, utilities). While included for sectoral analysis, it is not directly relevant to Angelonia Fashion or Turtle Movers unless their operations involve energy supply chains.
Protective Service Manual (Australian Government rules for cybersecurity)	The Australian Government's mandatory framework for both cyber and physical security in federal agencies is the PSPF. This framework mandates requirements covering four key areas: information security, personnel security, risk management, and incident response.	The PSPF is mandatory for Commonwealth Government departments and agencies. While private businesses, such as Angelonia Fashion or Turtle Movers, may choose to adopt its principles, adherence is not compulsory for standard commercial organisations.

4 Cyber Security Findings and Recommendations

Both Angelonia Fashion and Turtle Movers are actively engaged in handling personal data across various platforms, including online transactions, customer communications, and internal operations. This necessitates a strategic focus on strengthening their overall cybersecurity.

To ensure compliance with Australian privacy and consumer laws, mitigate cybersecurity risks, enhance data protection, and proactively prepare for evolving international and domestic regulatory landscapes, a set of targeted recommendations has been developed.

These measures are designed not only to improve immediate legislative adherence but also to future-proof both organisations against anticipated reforms in Australian privacy, surveillance, and consumer legislation.

Angelonia Fashion: Recommended Cyber-Legislation and Policy Actions

The following recommendations address key areas for Angelonia Fashion to enhance its cyber-legal compliance and preparedness.

1. Legislative and Regulatory Compliance (Australian Focus)

- **Privacy Policy Enhancement:** Immediately revise the Privacy Policy to fully incorporate the Australian Privacy Principles (APPs), specifically focusing on APP 1 (transparent privacy notices) and APP 11 (robust data security measures).
- **Data Lifecycle Management:** Implement detailed and auditable procedures for data retention and secure destruction to meet both taxation and privacy law obligations.
- **Consent Management:** Streamline and strengthen internal processes for obtaining and recording customer consent, ensuring automatic generation and secure storage of consent records.
- **Employee Training:** Introduce mandatory, regular refresher training on privacy and cybersecurity for all employees, ensuring it aligns with current legislative requirements.

2. International and Cross-Border Obligations

- **GDPR and Cookie Compliance:** Review and update the company website's cookie practices to establish GDPR-compliant consent mechanisms for international users.
- **Third-Party Compliance (Cloud/E-commerce):** Verify that all cloud-based services (hosting, Customer Relationship Management, marketing) adhere to relevant international security and privacy standards (e.g., GDPR, ISO 27001, PCI-DSS).
- **Data Transfer Transparency:** Update the online store's privacy notice to explicitly inform users about the potential transfer of their data overseas via cloud service providers.

3. Preparation for Upcoming Regulatory Reforms

- **Australian Privacy Act Reform:** Proactively prepare for the strengthening of the Privacy Act, which will involve:
    - Significantly increased penalties for breaches.
    - Mandatory Privacy Impact Assessments (PIAs) for all new systems and processes.
    - Tighter restrictions on online tracking and direct marketing activities.
- **Consumer Data Right (CDR) Expansion:** Monitor and prepare for the potential expansion of the CDR, which could introduce new requirements for how retail businesses manage and share customer data.

- **Surveillance and Tracking Laws:** Closely track reforms to surveillance legislation that may impose new restrictions or regulations on the use of website analytics, tracking technologies, and behavioural advertising.

Recommendations for Turtle Movers

A. Compliance with Legislation and Regulatory Requirements

- **Data Transparency (APP 11):** Enhance the Privacy Policy to provide clearer information on how customer data is retained and disposed of, ensuring compliance with Australian Privacy Principle (APP) 11.
- **Incident Management:** Establish a formal, documented internal process for the efficient handling and reporting of privacy incidents or customer complaints.
- **Identity Verification:** Implement stronger identity-verification protocols for customers making requests related to updates, cancellations, or changes to existing bookings.
- **Secure Storage:** Mandate the use of robust encryption and access control mechanisms for all systems storing sensitive customer data, including addresses, pickup/delivery locations, and insurance details.

B. Impact of International Cyber Security Legislation

- **Global Standards Compliance:** Ensure that cloud-based booking and communication platforms adhere to international privacy and security standards. This includes compliance with the **Payment Card Industry Data Security Standard (PCI-DSS)** for all payment processing and **GDPR-like** protections for customers located overseas.
- **Website Transparency:** Update the website's disclosures regarding tracking and cookie usage to satisfy international requirements for user transparency and consent.

C. Preparing for Potential Upcoming Reforms

- **Privacy Act Reforms:** Proactively prepare for anticipated changes to the Privacy Act, specifically those that will mandate:
    - Implementing enhanced security measures.
    - Providing clearer and more concise privacy notices.
    - Adhering to shorter mandatory data breach reporting timelines.
- **Expanded Definition of Personal Information:** Recognise that upcoming reforms may broaden the definition of "personal information" to include data like location information, which is highly relevant to a removalist business that manages detailed address logistics.
- **Monitoring Other Reforms:** Actively monitor proposed changes to surveillance and consumer laws, as these may necessitate updates to website consent mechanisms, disclosures within the online booking process, and general data-handling transparency practices.

5 Privacy Policies and Best Practices Review

A review of the organisation's privacy documentation was conducted to determine its alignment with the Australian Privacy Principles (APPs) and assess compliance with current privacy, security, and data-handling standards. This involved examining the clarity, completeness, and accuracy of the organisation's Privacy Policy, alongside an evaluation of how well operational practices adhere to privacy obligations. The compliance of each element was assessed to pinpoint existing gaps and recommend necessary improvements.

Privacy Policy Review (Angelonia Fashion)

POLICY	STANDARDS APPs	REVIEW DETAILS	COMPLIANCE			
			Full	Partial	Poor	Non-Compliance
Privacy Policy	APP 1 – Transparency	While the policy outlines the purpose and categories of data, it currently lacks a detailed articulation of the methods for governance, storage, and protection.	No	Yes	No	No
	APP 2 – Anonymity & Pseudonymity	No mention of whether customers can use services anonymously where lawful.	No	No	Yes	No
	APP 5 - Notification of Collection	Does not explain how customers are notified when data is collected.	No	No	Yes	No
	APP 6 - Use of Disclosure	The company utilises states' data for both transactional purposes and marketing initiatives. While consent receipts are employed for data disclosure, the documentation lacks specific detail regarding secondary data uses.	NO	Yes	NO	NO
	APP 11 - Security of Information	The report mentions a "robust security system" but fails to provide specific details regarding encryption	No	Yes	No	NO

		methods, access control mechanisms, or established procedures for responding to a security breach.				
	APP 12 - Access to Personal Information	No instructions for customers to request access to their data.	No	No	Yes	No

Privacy Policy Review (Turtle Movers)

POLICY	STANDARDS APPs	REVIEW DETAILS	COMPLIANCE			
			Full	Partial	Poor	Non-Compliance
Privacy Policy	APP 1 - Transparency	Clearly explains the data collected and the rationale for its collection. Addresses the policies for data retention and secure disposal.	Yes	No	No	No
	APP 2 – Anonymity & Pseudonymity	No option for an anonymous service is mentioned.	No	No	Yes	No
	APP 5 – Notification of Collection	The document lacks an explanation of the procedure for informing users at the moment their data is collected.	No	No	Yes	No
	APP 6 – Use & Disclosure	Disclosure requires consent, except in legally mandated circumstances.	Yes	No	No	No
	APP 11 – Security of Information	While the discussion of secure storage and disposal is good, it needs to include more specific details regarding technical controls.	No	Yes	No	NO

	APP 13 – Correction of Information	Customers lack a defined procedure for requesting data corrections.	No	No	Yes	No

Best Practices - Angelonia Fashion

BEST PRACTICES	EVALUATION/SHORTCOMINGS	PROPOSED IMPROVEMENTS
Minimal Data Collection	Large amounts of customer and banking information are collected without adequate explanation as to the necessity of each item.	Implement a data minimisation policy by reviewing forms and removing non-essential fields.
Robust data security system	The policy addresses security but lacks specific technical controls and defined responsibilities.	Clear controls should be implemented, including encryption, multi-factor authentication (MFA), access control measures, endpoint protection, and a comprehensive breach response plan.

Best Practices - Turtle Movers

BEST PRACTICES	EVALUATION/SHORTCOMINGS	PROPOSED IMPROVEMENTS
Backup data	No details on frequency, encryption, or testing of backups.	Introduce daily automated backups, encrypted storage, and quarterly restore tests.
Protect data from insider threats	The document identifies insider threats but lacks detail on preventative processes such as logging and access control.	Mandatory training on insider threat awareness, coupled with the implementation of Role-Based Access Control (RBAC), continuous activity monitoring, and the principle of least privilege, is an essential security measure.

6 Privacy Compliance Findings and Recommendations

A comprehensive review of the privacy policies and operational procedures at Angelonia Fashion and Turtle Movers has revealed both compliant strengths and critical gaps when measured against the Australian Privacy Act 1988 (Cth) and the Australian Privacy Principles (APPs). This subsequent analysis details the core findings for each entity. The focus is on evaluating their current adherence to privacy legislation, assessing the efficacy of their internal privacy measures, and prescribing necessary improvements to ensure full compliance and robust privacy safeguards.

A. Angelonia Fashion – Findings and Recommendations

a) Compliance with current privacy legislation

Findings:
Angelonia Fashion's current privacy policy shows partial adherence to the Australian Privacy Principles (APPs). While the policy broadly addresses the types of information collected, its usage, and a general commitment to privacy, it significantly lacks detail and coverage in several key APP areas.

Specifically, the policy needs improvement regarding:

- **Anonymity and Pseudonymity:** Options for individuals to interact anonymously or pseudonymously (APP 2).
- **Notification of Collection:** Clear notification when personal information is collected (APP 5).
- **Unsolicited Information:** Procedures for handling unsolicited personal information (APP 4).
- **Access and Correction:** The rights of individuals to access and correct their personal information (APPs 12–13).
- **Cross-Border Disclosure:** Detailed information on disclosing personal information overseas (APP 8).
- **Security:** Security requirements (APP 11) are only mentioned briefly and lack sufficient procedural detail.

In summary, Angelonia Fashion meets the foundational principles of the *Privacy Act* but needs to enhance transparency and provide clear procedures to achieve full compliance with all relevant APPs.

Required improvements:

- Clearly state options for customer anonymity and pseudonymity.
- Detail the process for notifying customers when their personal data is collected.
- Outline procedures for managing and disposing of unsolicited personal information.
- Establish a defined process for customers to access and request correction of their personal information.
- Specify if data is stored outside the country and describe the safeguards implemented for international storage.
- Enhance security control descriptions with simple, non-technical explanations of encryption, access controls, and breach management protocols.

b) Adequacy of current practices

Findings:
Angelonia possesses robust foundational practices, including data minimisation, consent receipts, privacy training, and rigorous access control. Nevertheless, documentation of these

practices lacks sufficient detail. Furthermore, essential operational processes, such as a formal breach response plan, secure data disposal procedures, and explicit data retention schedules, are either absent or inadequately defined.

Required improvements:

Recommended Security and Compliance Measures:

1. **Data Breach Response:** Establish a formal data breach response plan that strictly adheres to the Notifiable Data Breaches (NDB) scheme requirements.
2. **Technical Security:** Implement clear, documented technical security controls, including mandatory encryption standards, Multi-Factor Authentication (MFA), and comprehensive logging.
3. **Data Lifecycle Management:** Develop and document a comprehensive data retention and disposal schedule for all types of data, moving beyond minimal taxation-related requirements.

- **Privacy Governance and Training:** Conduct regular privacy audits and refresh employee training through scenario-based exercises to ensure ongoing compliance and awareness.

B. Turtle Movers – Findings and Recommendations

a) Compliance with current privacy legislation

Findings:
Turtle Movers exhibits a higher level of overall compliance compared to Angelonia. The policy is strong in clearly outlining the collection, use, retention, and disposal of personal information, and it adequately details disclosure practices. Nevertheless, compliance deficiencies persist. Specifically, the policy fails to address anonymity and pseudonymity (APP 2), the requirement to notify customers about information collection (APP 5), and the procedures for customer access to and correction of their information (APP 12–13). These omissions compromise transparency and limit customers' privacy rights.

Required improvements:

The following actions are necessary to ensure compliance and improve data management practices:

- **Anonymity and Pseudonymity:** Detail the possibilities and procedures for customers to interact anonymously or pseudonymously with MidTownIT.
- **Data Collection Notification:** Clearly outline the methods and timing for notifying customers when their data is collected.
- **Access and Correction Procedures:** Establish and make public the formal procedures allowing customers to access and correct their personal information.
- **Enhanced Security Controls (APP 11):** Strengthen and elaborate on the

explanation of security controls under Australian Privacy Principle (APP) 11 to clearly demonstrate robust protection measures for personal data.

b) Adequacy of current practices

Findings:
Turtle Movers maintains robust internal privacy practices, encompassing strong passwords, encryption, data backups, insider-threat controls, and layered security measures. While these measures are in place, some lack the necessary technical detail and specificity. For instance, the backup procedures do not specify frequency or testing protocols, and the insider-threat controls lack defined monitoring or role-based access measures.

Required improvements:

- **Data Backup and Recovery:** Formalise backup procedures, including defined schedules, strong encryption, and mandatory regular restoration testing.
- **Access Control:** Implement Role-Based Access Control (RBAC) and strictly enforce the principle of least privilege.
- **Insider Threat Mitigation:** Introduce user activity monitoring to effectively reduce the risks posed by insider threats.
- **Policy Continuous Improvement:** Ensure that the outcomes of complaint-handling processes are directly linked to subsequent policy updates.

7 Ethical behaviour in cyber security

Maintaining ethical behaviour is paramount in cybersecurity, particularly for organisations like Angelonia Fashion and Turtle Movers, whose business operations depend on the secure management of customer and employee data. The review of both organisations' privacy policies and practices highlighted that cybersecurity technicians are essential for upholding confidentiality, integrity, and legislative compliance. Therefore, a clear and well-structured Cybersecurity Code of Practice is necessary to ensure staff act responsibly and ethically. The subsequent section will detail an Ethics Code of Practice for cybersecurity technicians, including its distribution and implementation within the organisation.

7.1 Code of Practice- Angelonia Fashion

Ethics Code of Practice

1. Protection of Privacy and Confidentiality

Angelonia Fashion's cybersecurity personnel are required to respect and safeguard all personal, financial, and business data they handle. Access to information is strictly limited to that which is necessary for executing authorised tasks. Unauthorised disclosure, copying, or sharing of any information is strictly prohibited.

2. Lawful and Authorised System Access

The use of systems, tools, and data by technicians is restricted solely to legitimate organisational purposes. Strict prohibition is enforced against any form of unauthorised access, privilege escalation, or the bypassing of established security controls.

3. Integrity, Honesty, and Transparency

All security activities must be conducted with honesty and adherence to ethical standards. Technicians must report any vulnerabilities, system weaknesses, or breaches accurately and immediately. The manipulation of logs, concealment of errors, or alteration of any records is strictly prohibited.

4. Professional Conduct and Accountability

Cybersecurity staff are required to maintain a professional demeanour consistently. Technicians are individually accountable for the ethical and legal application of their access rights. Furthermore, all actions taken must be thoroughly documented, traceable, and in compliance with company policy.

5. Responsible Handling of Customer Data

Compliance with the Privacy Act 1988 and Angelonia Fashion’s internal privacy policies is mandatory for all technicians. Personal data collection, storage, and processing must be strictly limited to what is essential and must be secured by employing approved security controls.

6. Secure Behaviour and Best Practices

Technicians are required to maintain secure work practices, which include:

- Utilising strong, unique passwords.
- Implementing proper access control measures.
- Ensuring secure storage and transmission of data.
- Complying with all encryption and authentication standards.

7. Avoiding Conflicts of Interest

Company systems, tools, and information are strictly for business use and must never be utilised for personal gain. Management must be immediately informed of any potential conflicts of interest.

8. Reporting of Incidents and Concerns

Prompt reporting is mandatory for all suspected threats, breaches, or unethical behaviour. Technicians are required to fully support the subsequent investigation and cooperate with supervisors and management.

9. Commitment to Continuous Learning

Mandatory training and refresher programs are required for all cybersecurity staff. This ensures they remain current with emerging threats, technologies, and changes in legislation.

Distribution and Implementation of the Code

1. Distribution

The Ethics Code of Practice is disseminated to cybersecurity technicians through the following channels:

- **Onboarding Process:** The code is included in the Induction Packages for all new IT and security staff.
- **Direct Communication:** A digital copy is sent via Email Distribution to all current cybersecurity employees.
- **Central Repository:** It is permanently accessible on the Company Intranet under the “Policies and Procedures” section.
- **Mandatory Training:** The code is covered during annual cybersecurity and privacy refresher Training Sessions.
- **Physical Presence:** Printed Copies are displayed prominently within the IT Department/cybersecurity workspace.

2. Implementation

To ensure the Code of Practice is effectively followed, MidTownIT will implement the following mechanisms:

Staff Compliance and Understanding:

- **Acknowledgement Form:** All staff must sign a declaration confirming they have read and understood the Code of Practice.
- **Training and Updates:** Annual refresher training will be conducted to reinforce ethical responsibilities and update staff on any new requirements.

Management and Oversight:

- **Manager Briefings:** Supervisors are responsible for discussing ethical expectations during team meetings and individual performance reviews.
- **Monitoring and Audits:** Regular reviews of system logs, access records, and incident reports will be conducted to ensure continuous compliance.

Review and Accountability:

- **Annual Review:** The Code of Practice will be reviewed and updated annually to align with new laws, technologies, and evolving organisational needs.
- **Consequences for Breaches:** Non-compliance will lead to appropriate actions, ranging from mandatory retraining to disciplinary measures, or even termination, depending on the severity of the violation.

7.2 Ethical practices (this part covers both organisations).

Both Angelonia Fashion and Turtle Movers are heavily dependent on secure digital infrastructures to safeguard customer information, manage online sales, and ensure business continuity. To enhance their resistance to cyber threats, they should implement red team tools for systematic security testing and blue team tools for ongoing defensive operations. Crucially, the deployment of these tools must be underpinned by a robust ethical framework, as any misuse or unauthorised deployment carries severe risks, including legal action, data breaches, and significant operational disruption. The subsequent discussion will detail appropriate red and blue team tools, establish guidelines for their ethical application, and outline the repercussions of unethical conduct.

Red Team Tools (Offensive – for Controlled Testing Only)

The following is a list of key penetration testing tools and their primary functions:

1. **Metasploit:** A powerful framework for penetration testing, used to discover, exploit, and validate system vulnerabilities. It is essential for identifying weaknesses like unpatched systems, outdated software, or vulnerable services.
2. **Nmap:** A network scanning utility that maps network devices, identifies open ports, and detects running services. Red teams use it to pinpoint potential attack surfaces and entry points into a network.
3. **Hydra:** A tool dedicated to brute-force and password testing. Its purpose is to evaluate the robustness of authentication mechanisms, login systems, and user passwords.
4. **Burp Suite:** A comprehensive tool for web application security testing. It is used to uncover common web vulnerabilities, including cross-site scripting (XSS), SQL injection, insecure cookies, and session hijacking.

Blue Team Tools (Defensive – for Protecting Networks)

- **Security Information and Event Management (SIEM) – e.g., Splunk or Microsoft Sentinel**
    - Continuously monitors system logs.
    - Identifies unusual system behaviours.
    - Provides real-time alerts for suspicious activities.
- **Endpoint Detection and Response (EDR) – e.g., CrowdStrike or Carbon Black**
    - Used to detect malware, ransomware, and other attacks targeting endpoints.
    - Offers automated capabilities for threat blocking.

- **Firewall and Intrusion Prevention Systems (IPS) – e.g., pfSense, Snort**
    - Crucial for network security.
    - Filters traffic and blocks malicious data packets.
    - Detects intrusion attempts.
- **Vulnerability Scanners – e.g., Nessus**
    - Regularly examine the network and systems for known security weaknesses and missing software patches.
    - Vital for maintaining system integrity and compliance.

Ethical Practices When Using Red and Blue Team Tools in Public Networks

When engaging in cybersecurity activities on public or external networks, employees are required to adhere to the following ethical principles:

Mandatory Ethical Principles for External Network Cybersecurity Activities:

1. **Written Authorisation is Required:** Tools must **never** be used on any public, external, or third-party network without explicit, written permission from the owner organisation. Testing without consent is illegal under the *Computer Crimes Act* and the *Criminal Code Act 1995*.
2. **Operate Within Approved Environments Only:** All 'red team' or testing activity must be strictly confined to approved testing environments or simulated labs, and must not be conducted on live public systems.
3. **Ensure Confidentiality and Privacy:** Employees are prohibited from accessing, copying, or storing external user data, personal details, or business information during any testing process.
4. **Adherence to Organisational Policies:** All security testing must comply with the organisation's (e.g., Angelonia Fashion or Turtle Movers) approved testing policies, change-management procedures, and vulnerability reporting requirements.
5. **Tools for Security Improvement Only:** Tools such as Nmap, Metasploit, and Burp Suite must be used **strictly** for defence and security enhancement—not for unauthorised exploration or personal experimentation.
6. **Uphold Professional Integrity:** Employees must responsibly report identified vulnerabilities and must never exploit weaknesses for personal benefit or out of curiosity.

Unethical behaviour in cybersecurity poses significant and multifaceted risks to both Liberty Steel and Informa Australia, extending beyond technical issues to encompass legal, financial, ethical, and reputational domains.

The potential negative impacts are categorised as follows:

1. Legal and Regulatory Compliance Risks

Unethical data handling can violate Australian privacy legislation, including the Privacy Act 1988 and the Australian Privacy Principles (APPs), as well as industry-specific rules. Non-compliance can result in legal action, sanctions, and substantial fines for both organisations.

2. Erosion of Trust and Confidence

Incidents arising from unethical conduct—such as data breaches, data misuse, or the concealment of security incidents—can severely damage the confidence of customers and business partners. In data-sensitive industries, the loss of this critical trust is extremely difficult to regain.

3. Significant Financial Consequences

Cyber incidents stemming from unethical actions lead to various financial burdens:

- Costs associated with system recovery.
- Compensation payments to affected individuals.
- The necessity for increased cybersecurity investments.
- Loss of current and future business opportunities.
  In the most severe scenarios, staff's unethical actions can inflict major financial damage.

4. Reputation and Brand Damage

The public disclosure of unethical practices—including ignoring breach notifications, mishandling customer data, or deliberately bypassing security controls—can severely tarnish the brand image of Liberty Steel and Informa Australia. This affects customer perception, investor confidence, and long-term market competitiveness.

5. Operational Disruption and Downtime

Unethical actions, such as unauthorised access, improper system usage, or poor security practices, can interrupt normal business operations through:

- Loss of essential system functionality.
- Compromised data integrity.
- Service outages and significant downtime reduce overall organisational productivity.

6. Internal Disciplinary Action for Employees

Staff who engage in unethical conduct face a range of internal disciplinary measures, which may include:

- Formal warnings.
- Demotion.
- Termination of employment.
- Criminal charges in cases involving malicious intent or unauthorised system access.

7. Personal Accountability for Cyber Professionals

Cybersecurity personnel, who often hold elevated access privileges and specialised professional responsibilities, are particularly exposed. Unethical decisions may lead to

personal legal liability, including potential negligence claims.

UNETHICAL BEHAVIOUR	IMPACT ANALYSIS
Unauthorised use of penetration testing tools, such as Metasploit.	Unauthorised system compromise, service outages, and data loss are possible outcomes, potentially leading to breaches of the *Privacy Act 1988*. These consequences can result in a loss of trust and may trigger disciplinary or legal action.
Unauthorised access to confidential files without a legitimate business purpose ("snooping") is prohibited.	Undermines employee and customer trust, violating privacy and potentially breaching the Australian Privacy Principles (APPs). This can expose sensitive data, leading to disciplinary action and possible regulatory penalties.
Installing unapproved software or tools on company systems	Unauthorised software installation poses significant risks, including the introduction of malware, system vulnerabilities, and legal licensing issues. These actions can compromise overall system security and availability, resulting in cyber incidents and breaches of compliance.
Failing to report discovered vulnerabilities or breaches	Increased vulnerability to successful cyberattacks due to exploited weaknesses. This heightens the risk of data breaches, incurring legal penalties, and suffering reputational harm.

Identify three (3) downloading file-sharing services. For each service, identify its suitability and the security risks associated with it.

FILE-SHARING SERVICE (Downloading)	SUITABILITY	ASSOCIATED SECURITY RISKS
BitTorrent	Ideal for the efficient distribution of large files and compatible with open-source software.	Downloading pirated, malicious, or infected files poses a high risk. This can expose your IP address to attackers and result in legal copyright violations.

Dropbox	Appropriate for authorised cloud storage and collaborative business activities.	Potential risks include public exposure of files due to misconfigurations, company data leaks resulting from account theft, and the reliance on robust, secure access management for mitigation.
Google Drive	Offers secure cloud storage, facilitates sharing and collaboration, and integrates robustly with existing business platforms.	Misconfigured sharing links and phishing pose significant risks, potentially leading to public file exposure and account compromise. Strong access controls are therefore essential.

8 Conclusion

This report has provided an analysis of the privacy legislation, regulatory frameworks, policies, and cybersecurity practices pertinent to both organisations.

The review found that while foundational privacy policies and operational controls are in place, significant gaps persist. These include a lack of compliance transparency, weaknesses in data governance, insufficient user awareness, and inconsistent adherence to national privacy standards like the Australian Privacy Principles (APPs). Addressing these deficiencies is crucial for maintaining legal compliance, safeguarding the integrity of business data systems, and preserving stakeholder confidence.

Furthermore, the importance of ethical conduct in cybersecurity operations was underscored. Unauthorised actions—such as misuse of security tools, accessing systems without permission, or downloading prohibited content—can trigger operational disruptions, severe legal and financial repercussions, and reputational harm. Mitigating these risks requires establishing a robust internal code of practice, supported by ongoing training and a system of enforced accountability.

The report also examined current and forthcoming legislative reforms concerning privacy, consumer protection, and surveillance. These reforms will increase expectations for greater transparency, mandatory breach notification, responsible data handling, and enhanced protection for personal information. Proactive implementation of improvements now will not only secure compliance but also boost operational resilience and prepare both organisations for the continually evolving digital threat landscape.

In conclusion, the adoption of strengthened policy enforcement, continuous cybersecurity education, and rigorous governance practices is essential for both organisations to operate securely, ethically, and in full compliance with contemporary legislative requirements.

Appendix

Organisation policies, procedures and best practices documentation

POLICES for Angelonia Fashion

PRIVACY POLICY

Angelonia Fashion is committed to protecting the privacy of the personal information of our clients and employees. We value and respect the privacy of the people we do business with and who work for our company.

Angelonia's Privacy Policy complies with the Australian Privacy Act 1988 (Cth) and other relevant privacy laws and regulations.

This Privacy Policy covers all employees and clients of Angelonia Fashion and outlines how we collect, use, retain and disclose personal information gathered to carry out our business activities.

Information we may collect

- Contact information
- Name and surname
- Address
- Email address
- Phone number
- Transaction details and history
- Order details
- Payment method
- Returns details
- Refunds
- Banking and/or credit details
- Details of payment method (For example, institution, account)
- Correspondence and communication
- Emails
- Phone messages
- Phone records

How data is collected

We collect data from your online transactions. This includes information on your online purchases and online interactions.

How data is used

We use the data collected from your online transactions to:

- process your online purchases
- deliver a personalised experience
- manage internal administrative and taxation processes
- support our marketing strategy

We retain your personal information linked to sales for the period of time required by the taxation department. For other situations, we only retain the data collected for the duration of the business activity.

Disclosure of information

We use a system consent receipt each time we intend to disclose your information to third parties. For all other situations, we will disclose your personal information only as permitted by the law.

Cookies

Angelonia Fashion uses cookies on its website. Cookies do not personally identify you, but your devices, browsers and navigation patterns on our website. The purpose of the cookies is to improve your online experience. You can disable cookies on your browser, but this may affect the way the website displays.

Marketing information

It is your choice to subscribe to receive marketing communications and information from Angelonia Fashion. You can subscribe and unsubscribe to our marketing emails and SMS messages at any time.

Third-party data collection

If you access a third-party website through our website, the third-party website may collect your personal information. We take no responsibility for third-party websites' privacy policies or lack of policies.

Concerns and complaints

To lodge a complaint against this policy, download the complaint form from our website and follow the lodgement instructions. All complaints are addressed promptly and professionally.

Contact us if you have any questions or concerns regarding this policy. Contact details:

- Email: angelonia@af.com.au
- Phone: 123456789

PRIVACY PROCEDURES for Angelonia Fashion

PRIVACY POLICY for Distribution and Maintenance Procedure

Purpose: This procedure outlines the actions that Angelonia Fashion takes to ensure the distribution and maintenance of the company's Privacy Policy.

Scope: All employees of Angelonia Fashion

Responsibilities: The responsibility for distributing and maintaining the Privacy Policy over time rests with management.

Distribution options:

- All employees of Angelonia Fashion are made aware of the Privacy Policy when first joining the company during the induction or orientation process.
- After the induction session is completed, all new employees are emailed the Privacy Policy and are invited to raise any questions or concerns.
- All employees are provided with ongoing privacy training and support through refresher programs every twelve months and are issued with a completion certificate.
- Employees can access the Privacy Policy on the company intranet and also on the company website.
- Angelonia Fashion's clients can access the Privacy Policy through the company website. They are encouraged to raise questions or concerns with management via email.

Maintenance options

Policy scheduled reviews:

- The Privacy Policy is reviewed every twelve months and updated before a new round of refresher privacy training takes place.
- After a policy review:
- A notification email is sent to all employees, including the policy, or a link to it.
- The website is updated to include the newly updated policy.
- Privacy refresher training sessions are scheduled.

What can trigger an unscheduled review?

- A change in privacy legislation will result in a policy review to ensure compliance with legislation.
- Once the policy is updated in accordance with the new legislation, the steps outlined in "After a policy review" in the Review section will take place.
- Another event that can trigger an out-of-scope review is an unusual increase in the number of complaints against the policy from employees and clients. This will trigger a review and subsequent update of the policy.

ORGANISATIONAL PRACTICES for Angelonia Fashion

Angelonia Fashion has in place a number of practices to ensure that employees adhere to company policy and offer the best possible service to customers. This document outlines the privacy and handling of customer query practices.

Privacy practices:

- Secure password policy.
- Identify and classify sensitive data.
- Encrypt sensitive data.
- Control access to sensitive data.
- Minimal data collection. Collect only the data required to carry out the transaction.
- Use a system of consent receipts. The customer receives a consent receipt each time they consent to processing personal data and can keep the receipt as proof.
- Implement a robust data security system.
- Compulsory privacy training and awareness of all employees.

Practices to handle customer queries:

- Timely handling of refunds and faulty products (garments).
- 24-hour response to customer queries regarding products and delivery arrangements.
- Do not assume all customers want the same thing.
- Adapt to customer communication styles. If appropriate, use your customer’s language.
- Know the ropes. Customers need to be reassured that the person they are talking to knows the system.
- Honesty is the best communication policy.
- Avoid close-ended responses when dealing with clients, as they can block communication.
- Keep calm and professional at all times.
- The priority is to address and resolve the customer's issue.

POLICES for TURTLE MOVERS
PRIVACY POLICY

Turtle Movers is committed to protecting the privacy of the personal information of our clients and employees. We value and respect the privacy of the people we do business with and who work for our company.

Turtle Movers' Privacy Policy complies with the Australian Privacy Act 1988 (Cth) and other relevant privacy laws and regulations.

This Privacy Policy covers all employees and clients of the company and outlines how we collect, use, retain and disclose personal information gathered to carry out our business activities.

Information we may collect

- Contact information
- Name and surname
- Pickup address
- Delivery address
- Email address
- Phone number
- Transaction details and history
- Bookings
- Cancellations and rescheduling
- Insurance
- Payment method
- Refunds
- Rewards and loyalty benefits
- Banking and/or credit details
- Details of payment method (For example, financial institution, account)
- Correspondence and communication
- Emails
- Phone messages
- Phone records

How data is collected

Turtle Movers collect data from your online transactions. Transactions include information on your online removalists' queries, service bookings and payments.

How data is used

We use the data collected from your online transactions to:

- process your online removalists bookings and related activities
- deliver a personalised experience

- manage internal administrative and taxation processes
- support our marketing strategy

We retain your personal information linked to removalists' jobs for the period of time required by the taxation department. For other situations, we only retain the data collected for the duration of the business activity.

Disclosure of information

Turtle Movers does not share or sell your data to third parties and will seek your consent if personal data needs to be shared with a third party, such as an insurance company.

There may be circumstances where we need to disclose your data to legal authorities, and we will do so as permitted by the law.

Retention and disposal of data

Turtle Movers will keep your personal contact details and transaction data stored securely for the required period of time to comply with taxation legislation. After that period has elapsed, your data will be destroyed.

Concerns and complaints

To lodge a complaint against this policy, download the complaint form from our website and follow the lodgement instructions. All complaints are addressed promptly and professionally.

Contact us if you have any questions or concerns regarding this policy. Contact details:

- Email: turlemovers@tm.com.au
- Phone: 123456789

PRIVACY PROCEDURES for Turtle Movers

Lodging a Privacy Complaint

Purpose: This procedure outlines the actions that need to be carried out to lodge a Privacy Policy complaint.

Scope: All employees and clients of Turtle Movers

Responsibilities:

The responsibility for actioning, processing and resolving privacy complaints falls on Turtle Movers' management.

Lodging a privacy complaint:

- To lodge a privacy complaint, you need to access the Privacy Complaint Form from the company website. It is located in the legal section of the website. You can request the form to be sent to you via email.

- Once you have the form, complete all sections with as many details as possible to ensure that there are no delays in processing the complaint.
- Submit the completed form if you accessed the website form, or email the form if you requested one via email.

Acknowledgement of privacy complaint

- Turtle Movers take complaints seriously, and will endeavour to acknowledge receipt of the complaint within 48 hours.

Processing a privacy complaint

- Management will investigate the complaint within 7 days of receiving it. During this period, they may contact the complainant if further information is required.
- In most cases, complaints are resolved in conversation with the complainant by addressing all the issues and concerns and negotiating a resolution.
- If more information or investigation is required and the process is delayed, management will keep the complainant continuously updated on the process.

Resolving and closing a privacy complaint

- Once processing, investigation and communication with the complainant has concluded, management will communicate the resolution to the complainant. If both parties agree at this stage, the resolution will be formally documented and archived by management.
- If it is pertinent, management will formally apologise to the complainant and take the necessary measures to eradicate the problem.
- If a mutually agreeable resolution has not been reached, either party may decide to get independent legal advice on the matter.
- Turtle Movers is committed to resolving all complaints promptly and amicably.

PRIVACY PRACTICES for TURTLE MOVERS

Turtle Movers has in place a set of privacy practices to ensure that employees comply with company policy regarding privacy. These practices aim to protect the privacy of customers' personal data.

Privacy practices:

- Enforce strong passwords.
- Employ encryption for sensitive data.

- Compulsory privacy training and awareness of all employees.
- Back up data.
- Protect data from insider threats. This type of threat may originate from:
- Negligent employees
- Third-Party Partners
- Ex-employees
- Policy Evaders
- Use end-point security systems to protect data
- Conduct proper disposal of electronic and physical copies of personal and protected data.
- Implement a trifecta of physical, technical, and administrative controls to safeguard personal information.